

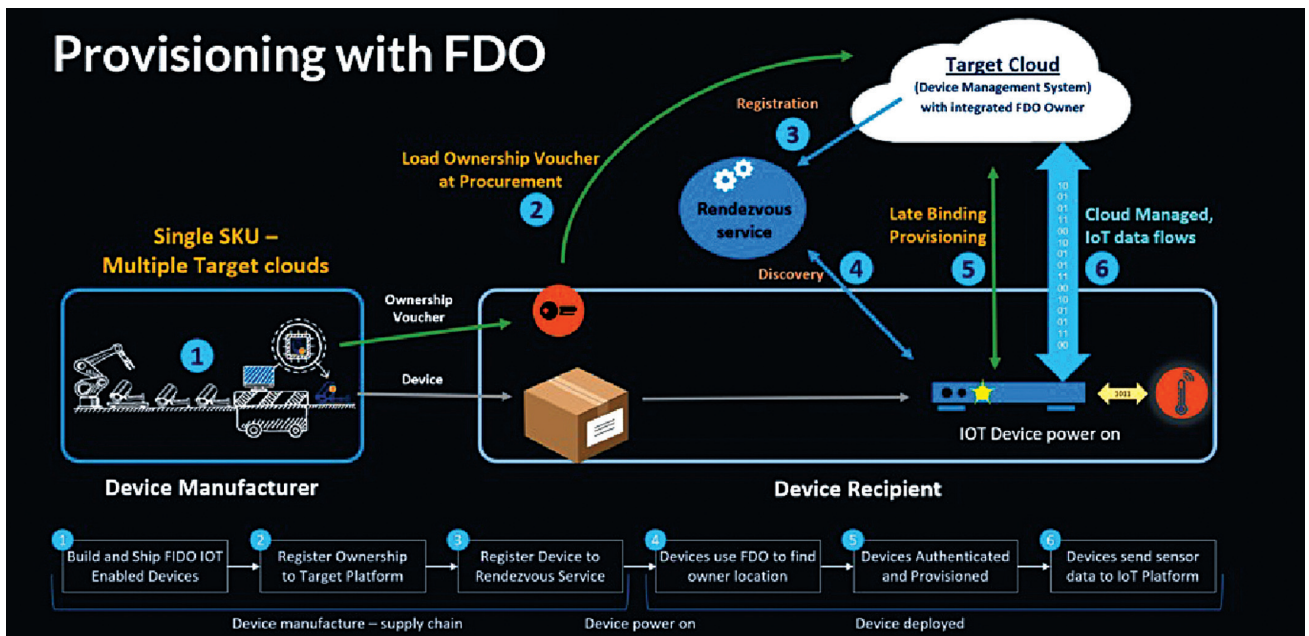


Fig. 1: Provisioning IoT devices with FDO (Source: FIDO Alliance)

it in the specified service seamlessly.

The FDO specification involves the use of an FDO software client installed on the IoT device when it is manufactured. A Root of Trust (RoT) key is also generated to uniquely identify each device and is saved within it, preferably within the trusted platform module (TPM) or any other secure element from which it cannot be tampered with. It can also be placed in the file system, though that is not very secure. A corresponding supply chain token is also generated, and it moves as and when the device is transferred from the manufacturer to the wholesaler, retailer, and so on, and finally to the customer. The customer enrolls it on the target cloud. When the device is powered on and connected to the internet, it automatically gets provisioned taking all configurations from the target cloud.

This can be explained with the help of an example. Let us assume there is a security camera manufacturer M. This company produces five security cameras, out of which company A purchases three and company B purchases two. All five security cameras have a unique RoT

key stored in their secure element. The three cameras that A purchases are sold to retailer R1 while the two B purchases go to retailer R2. When company A powers on the camera purchased, it is automatically connected to company A's server, and can be streamed by its administrator without any configuration on the camera. The same goes with the cameras procured by company B.

You may wonder how this is possible so seamlessly without any configuration on the camera. This is what happens behind the scenes. When manufacturer M manufactured the five cameras, each had a unique RoT stored in the secure element. When the devices are sold to the resellers, they use the reseller tool to generate an 'ownership token' when selling the product to the end user. Here, company A and company B are the end users. Hence, company A enrolls its 'ownership tokens' on the server while company B does the same. Now when the camera is powered on, it contacts a rendezvous server, which may be of the camera manufacturer, and authenticates itself with device attestation. The

rendezvous server redirects the devices to the servers of company A and company B, from where it can automatically install the configurations. This is a completely automated and seamless process, involving no manual configuration. Now, after the automated configuration is done, the device is ready to stream video feeds to the company servers.

It's pretty clear now that the FDO standard, when implemented for IoT devices, especially in industrial scenarios, can reduce human effort manifold and also provide a secure way of onboarding devices.

In the case of manual device onboarding, technicians very often get to know the credentials of the company network in order to connect devices to it. This can prove to be a major security risk if the credentials are leaked. FDO, on the other hand, uses the public key crypto system to securely onboard the IoT devices without any hassle or security lapses. It is ideal for corporate and industrial devices. **EFY**

This article was first published in December 2022 issue of Open Source For You magazine.